

Com base nas informações fornecidas sobre a arquitetura, stack tecnológica e a estrutura do repositório do Projeto Continuum, apresento a avaliação de segurança da informação cruzada com os requisitos exigidos.

Sumário Executivo

O Projeto Continuum demonstra um nível de maturidade de segurança estruturado e promissor, com foco claro na proteção de informações clínicas sensíveis e mitigação de falhas de comunicação em ambientes de saúde. A arquitetura web fundamentada em HTML, PHP e JavaScript integra um banco de dados relacional com restrições de integridade e adota o Controle de Acesso Baseado em Papéis (RBAC). O sistema atende a diversos requisitos críticos de conformidade com a LGPD e rastreabilidade. No entanto, a análise identifica lacunas referentes à disponibilidade sistêmica contra ataques de rede e documentação de algoritmos de criptografia em repouso.

Auditoria de Requisitos (PDF vs. Realidade Analisada)

Categoria do Requisito	Status Analisado	Justificativa / Evidência
1. Autenticação (2FA)	Atendido	A funcionalidade de Autenticação de dois fatores (2FA) está implementada. O repositório contém endpoints específicos como verificar2FA_paciente.php e verify-2fa.php.
1. Autenticação (Força Bruta)	Parcialmente Atendido	A proteção contra força bruta (rate limit, bloqueio, atraso) é exigida. Não há menção explícita a rate limiting ou WAF nas tecnologias citadas.
2. Recuperação de Senha	Atendido	A funcionalidade de recuperação de senha está implementada. O sistema possui o endpoint senha.php e telas dedicadas no cliente (new_senha, password).

3. Criptografia (Tráfego)	Atendido	A comunicação deve ser protegida por TLS/HTTPS. A presença do diretório config/certs/ca.pem no repositório indica o suporte à comunicação segura.
3. Criptografia (Repouso)	Não Atendido	É exigido que os dados sensíveis sejam criptografados em repouso e que as chaves sejam protegidas. O escopo tecnológico fornecido não detalha os algoritmos de criptografia em repouso utilizados (ex.: AES).
4. LGPD (Exclusão)	Atendido	A funcionalidade de exclusão dos dados pessoais é exigida. O sistema implementa rotinas de exclusão lógica para a preservação do histórico clínico.
4. LGPD (Exportação)	Atendido	A funcionalidade de exportação dos dados é exigida. O repositório possui a API exportar.php e evidências visuais de exportação de dados.
4. LGPD (Consentimento)	Atendido	O registro explícito de consentimento e a possibilidade de revogação são exigidos. O sistema viabiliza um módulo de gestão de consentimento dos direitos do paciente e possui o arquivo revoga_conta.php.

5. Auditoria e Logs	Atendido	O registro de logs de autenticação e a proteção contra alteração dos logs são exigidos. O sistema assegura rastreabilidade por meio de logs inalteráveis contendo carimbo de tempo e autoria (receptor e transmissor). O repositório contém a API registrarLog.php.
---------------------	----------	---

Análise Detalhada por Pilar da Tríade CIA

Confidencialidade (Tríade CIA)

- **Controle de Acesso:** O sistema protege informações clínicas sensíveis por meio do Controle de Acesso Baseado em Papéis (RBAC).
- **Gestão de Privacidade:** O projeto viabiliza um módulo de gestão de consentimento dos direitos do paciente, alinhando-se às restrições legais impostas pela LGPD.
- **Criptografia em Trânsito:** A presença de certificados digitais (ca.pem) aponta para o uso de TLS/HTTPS, o que atende ao requisito de comunicação protegida.
- **Vulnerabilidades:** Não há evidências ou documentação detalhada sobre o uso de algoritmos criptográficos (como o AES) para a proteção de dados sensíveis em repouso.

Integridade (Tríade CIA)

- **Validação de Entradas:** A implementação conta com módulos que aplicam validações rígidas de preenchimento e validação lógica de conformidade.
- **Dados Críticos:** A arquitetura impõe a obrigatoriedade de preenchimento de campos críticos, como sinais vitais e medicações pendentes, para a transição do cuidado.
- **Consistência de Dados:** O sistema utiliza um banco relacional com restrições de integridade.
- **Imutabilidade de Logs:** A rastreabilidade do sistema é assegurada por meio de logs inalteráveis, que contêm carimbo de tempo e autoria tanto do receptor quanto do transmissor.

Disponibilidade (Tríade CIA)

- **Preservação Histórica:** O sistema implementa rotinas de exclusão lógica, garantindo a preservação do histórico clínico e mantendo os dados disponíveis para fins médicos autorizados.
- **Vulnerabilidades:** A stack tecnológica listada (HTML, PHP e JavaScript) não menciona mecanismos explícitos de resiliência, redundância, tolerância a falhas ou proteção contra ataques de negação de serviço (DoS/DDoS).

Matriz de Riscos

Risco Identificado	Impacto	Probabilidade	Classificação	Justificativa
Ausência de mitigação DoS/DDoS	Alto	Média	Alto	Sistemas web de saúde são alvos frequentes; indisponibilidade pode comprometer a transição de cuidados clínicos.
Falta de criptografia em repouso	Alto	Baixa	Médio	Caso o banco de dados seja comprometido, os dados clínicos sensíveis podem ser expostos em texto claro se não houver criptografia em repouso adequada.
Proteção contra força bruta não evidenciada	Médio	Alta	Médio	A falta de rate limiting explícito pode permitir que agentes maliciosos tentem contornar senhas ou o 2FA.

Plano de Ação e Recomendações

1. Proteção de Disponibilidade (Urgência Alta):

- Implementar e documentar o uso de WAF (Web Application Firewall) e CDNs para fornecer resiliência contra ataques de negação de serviço (DoS/DDoS).

- Estabelecer planos de contingência e redundância de servidores para o backend em PHP.

2. Proteção de Autenticação (Urgência Média):

- Garantir a implementação e configurar os parâmetros de rate limiting (limite de taxas) e bloqueio temporário de contas nas rotas de login (login.php) para evitar ataques de força bruta, conforme exigido pelos requisitos.

3. Criptografia em Repouso (Urgência Média):

- Documentar e aplicar a estratégia de criptografia para dados em repouso utilizando um algoritmo seguro, como o AES, atendendo de forma integral aos requisitos de comunicação e criptografia.

4. Gestão de Credenciais (Urgência Baixa/Revisão):

- Verificar tecnicamente se as senhas estão sendo armazenadas utilizando um hash criptográfico seguro (Argon2, bcrypt ou PBKDF2) juntamente com um salt criptográfico único por usuário.